

**VULNERABILITY ANALYSIS
ASSESSMENT FINDINGS REPORT**

Target: Metasploitable 2

Table of Contents

Table of Contents.....	2
1. Executive Summary	3
Network Attack Path	3
2. Scope & Methodology	3
2.1 Environment Verification	3
2.2 Scanning Tools.....	4
2.3 Service Discovery (Nmap)	5
3. Findings Summary	7
4. Detailed Findings	8
F-01: vsftpd 2.3.4 Backdoor Command Execution (Critical)	8
F-02: UnrealIRCd 3.2.8.1 Backdoor Command Execution (Critical).....	10
F-03: Samba “username map script” Command Execution (Critical).....	12
F-04: Java RMI Registry Insecure Default – Remote Code Execution (Critical)	14
F-05: OpenSSL CCS Injection (Man-in-the-Middle) (High).....	16
5. Remediation Summary & Priorities.....	16
5.1 Why CVSS Is Not the Only Factor	17
6. References.....	17

1. Executive Summary

This report presents the results of a vulnerability analysis performed against the Metasploitable 2 target host. The objective was to discover, classify, validate, and prioritise vulnerabilities present on the system, then recommend remediation in line with industry best practice (NIST SP 800-115 and the OWASP Testing Guide).

Overall Risk Level: CRITICAL

Vulnerabilities reported: 5 (4 Critical, 1 High). Note: the scan exposed many additional open services and version-based issues; the five findings below are the validated, highest-impact issues selected for analysis.

Biggest concern: The host exposes multiple unauthenticated remote-code-execution paths that grant root access with trivial effort. The vsftpd 2.3.4 service contains a confirmed backdoor that was exploited during testing to obtain a root shell (uid=0). Any attacker with network access to the host can fully compromise the system, read or destroy all data, and use it to pivot deeper into the network. Because working public exploits exist for every Critical finding, the realistic time-to-compromise is minutes.

Network Attack Path

A typical compromise scenario against this host requires no credentials and follows a short chain:

Attacker (192.168.56.103) → TCP/21 vsftpd 2.3.4 backdoor → root shell (uid=0) → full host control → data exfiltration / lateral movement.

Alternative entry points (Samba TCP/139-445, UnrealIRCd TCP/6667, Java RMI TCP/1099) reach the same outcome – unauthenticated code execution – providing the attacker with several redundant ways to gain root.

2. Scope & Methodology

Assessment Type	Internal, network-level vulnerability analysis
Scan Type	Unauthenticated (black-box, no credentials supplied)
Target (Victim)	192.168.56.105 – Metasploitable 2 (Linux)
Attacker Host	192.168.56.103 – Kali Linux
Network	VirtualBox Host-Only (192.168.56.0/24)
Tools Used	Nmap (-sV -sC, NSE vuln & vulners scripts), OpenVAS / GVM, CVE.org / NVD, CVSS v3.1 Calculator (FIRST)
Testing Date	7 June 2026 (single lab session)

Testing followed the standard phases of a vulnerability assessment: Planning (defining scope and target), Discovery (port, service and version enumeration), Analysis (mapping services to known CVEs, CWEs and CVSS scores, and manually validating findings), and Reporting (documenting confirmed issues with remediation).

2.1 Environment Verification

The attacker (Kali) and victim (Metasploitable 2) were confirmed to reside on the same Host-Only subnet.

```
zsh: corrupt history file /home/kali/.zsh_history
(kali@kali)-[~]
$ ifconfig
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 192.168.56.103 netmask 255.255.255.0 broadcast 192.168.56.255
    inet6 fe80::a00:27ff:fe00:6050 prefixlen 64 scopeid 0<link>
    ether 08:00:27:00:60:50 txqueuelen 1000 (Ethernet)
    RX packets 54 bytes 10675 (10.4 KiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 30 bytes 4300 (4.1 KiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536
    inet 127.0.0.1 netmask 255.0.0.0
    inet6 ::1 prefixlen 128 scopeid 0<host>
    loop txqueuelen 1000 (Local Loopback)
    RX packets 1452 bytes 117504 (114.7 KiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 1452 bytes 117504 (114.7 KiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

(kali@kali)-[~]
$
```

Figure 1 – Attacker (Kali) interface: 192.168.56.103

```
Metasploitable 2 [Running] - Oracle VM VirtualBox
File Machine View Input Devices Help

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
to mail.
sfadmin@metasploitable:~$ ifconfig
eth0
    Link encap:Ethernet HWaddr 08:00:27:0b:f6:0e
    inet addr:192.168.56.105 Bcast:192.168.56.255 Mask:255.255.255.0
    inet6 addr: fe80::a00:27ff:fe0b:f60e/64 Scope:Link
    UP BROADCAST RUNNING MULTICAST MTU:1500 Metric:1
    RX packets:15 errors:0 dropped:0 overruns:0 frame:0
    TX packets:29 errors:0 dropped:0 overruns:0 carrier:0
    collisions:0 txqueuelen:1000
    RX bytes:4426 (4.3 KB) TX bytes:3638 (3.5 KB)
    Base address:0xd020 Memory:f0200000-f0220000

lo
    Link encap:Local Loopback
    inet addr:127.0.0.1 Mask:255.0.0.0
    inet6 addr: ::1/128 Scope:Host
    UP LOOPBACK RUNNING MTU:16436 Metric:1
    RX packets:91 errors:0 dropped:0 overruns:0 frame:0
    TX packets:91 errors:0 dropped:0 overruns:0 carrier:0
    collisions:0 txqueuelen:0
    RX bytes:19301 (18.8 KB) TX bytes:19301 (18.8 KB)

sfadmin@metasploitable:~$
```

Figure 2 – Victim (Metasploitable 2) interface: 192.168.56.105

2.2 Scanning Tools

OpenVAS / GVM was deployed for automated vulnerability scanning, alongside Nmap for service discovery and script-based vulnerability detection.

```
Releasing lock on /var/lib/gvm/feed-update.lock
[*] Checking Default scanner
08b69003-5fc2-4037-a479-93b440211c73 OpenVAS /run/ospd/ospd-openvas.sock 0 OpenVAS Default
[i] No need to alter default scanner

[+] Done
[*] Please note the password for the admin user
[*] User created with password '30c49fd6-2584-4398-973a-03ff1cfe30d6'.

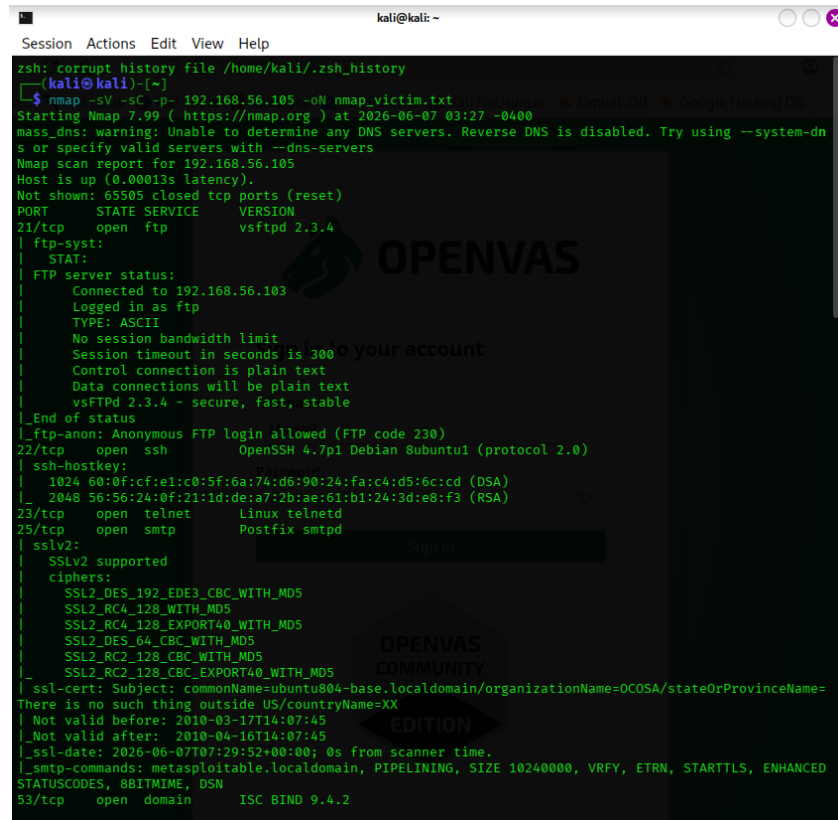
[>] You can now run gvm-check-setup to make sure everything is correctly configured

(kali@kali)-[~]
$ sudo gvm-start
[>] Please wait for the GVM services to start.
[>]
[>] You might need to refresh your browser once it opens.
```

Figure 3 – OpenVAS / GVM setup completed

2.3 Service Discovery (Nmap)

An Nmap service/version scan (nmap -sV -sC -p- 192.168.56.105) enumerated the open ports and running service versions used as the basis for analysis.



```
zsh: corrupt history file /home/kali/.zsh_history
kali@kali:~$ nmap -sV -sC -p- 192.168.56.105 -oN nmap_victim.txt
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-07 03:27 -0400
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dn
s or specify valid servers with --dns-servers
Nmap scan report for 192.168.56.105
Host is up (0.00013s latency).
Not shown: 65505 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
|_ftp-syst:
|_STAT:
|_FTP server status:
|_   Connected to 192.168.56.103
|_   Logged in as ftp
|_   TYPE: ASCII
|_   No session bandwidth limit
|_   Session timeout in seconds is 300
|_   Control connection is plain text
|_   Data connections will be plain text
|_   vsFTPd 2.3.4 - secure, fast, stable
|_End of status
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
|_ssh-hostkey:
|_   1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_   2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
|_sslv2:
|_SSLv2 supported
|_ciphers:
|_   SSL2_DES_192_EDE3_CBC_WITH_MD5
|_   SSL2_RC4_128_WITH_MD5
|_   SSL2_RC4_128_EXPORT40_WITH_MD5
|_   SSL2_DES_64_CBC_WITH_MD5
|_   SSL2_RC2_128_CBC_WITH_MD5
|_   SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
|_ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=
There is no such thing outside US/countryName=XX
|_Not valid before: 2010-03-17T14:07:45
|_Not valid after: 2010-04-16T14:07:45
|_ssl-date: 2026-06-07T07:29:52+00:00; 0s from scanner time.
|_smtp-commands: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCED
STATUSCODES, 8BITMIME, DSN
53/tcp    open  domain       ISC BIND 9.4.2
```

Figure 4 – Nmap service scan (ports 21–53)

```
kali@kali: ~
Session Actions Edit View Help

STATUSCODES, 8BITIME, DSN
53/tcp open domain ISC BIND 9.4.2
| dns-nsid:
| bind.version: 9.4.2
80/tcp open http Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_ http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
|_ http-title: Metasploitable2 - Linux
111/tcp open rpcbind 2 (RPC #100000)
| rpcinfo:
|_ program version port/proto service
|_ 100000 2 111/tcp rpcbind
|_ 100000 2 111/udp rpcbind
|_ 100003 2,3,4 2049/tcp nfs
|_ 100003 2,3,4 2049/udp nfs
|_ 100005 1,2,3 42692/tcp mountd
|_ 100005 1,2,3 48213/udp mountd
|_ 100021 1,3,4 34444/udp nlockmgr
|_ 100021 1,3,4 46445/tcp nlockmgr
|_ 100024 1 49549/tcp status
|_ 100024 1 54585/udp status
139/tcp open netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp open netbios-ssn Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
512/tcp open exec netkit-rsh rexecd
513/tcp open login OpenBSD or Solaris rlogind
514/tcp open shell Netkit rshd
1099/tcp open java-rmi GNU Classpath grmiregistry
1524/tcp open bindshell Metasploitable root shell
2049/tcp open nfs 2-4 (RPC #100003)
2121/tcp open ftp ProFTPD 1.3.1
3306/tcp open mysql MySQL 5.0.51a-3ubuntu5
| mysql-info:
|_ Protocol: 10
|_ Version: 5.0.51a-3ubuntu5
|_ Thread ID: 8
|_ Capabilities flags: 43564
|_ Some Capabilities: SupportsTransactions, SwitchToSSLAfterHandshake, LongColumnFlag, Support41Auth,
|_ Speaks41ProtocolNew, SupportsCompression, ConnectWithDatabase
|_ Status: Autocommit
|_ Salt: X0%h\5Pv~;G5r^aM70ss
3632/tcp open distccd distccd v1 ((GNU) 4.2.4 (Ubuntu 4.2.4-1ubuntu4))
5432/tcp open postgresql PostgreSQL DB 8.3.0 - 8.3.7
|_ ssl-date: 2026-06-07T07:29:52+00:00; 0s from scanner time.
|_ ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=
|_ There is no such thing outside US/countryName=XX
|_ Not valid before: 2010-03-17T14:07:45
|_ Not valid after: 2010-04-16T14:07:45
5900/tcp open vnc VNC (protocol 3.3)
| vnc-info:
|_ Protocol version: 3.3
|_ Security types:
|_ VNC Authentication (2)
6000/tcp open X11 (access denied)
6667/tcp open irc UnrealIRCd
6697/tcp open irc UnrealIRCd
8009/tcp open ajp13 Apache Jserv (Protocol v1.3)
|_ ajp-methods: Failed to get a valid response for the OPTION request
8180/tcp open http Apache Tomcat/Coyote JSP engine 1.1
|_ http-favicon: Apache Tomcat
|_ http-title: Apache Tomcat/5.5
|_ http-server-header: Apache-Coyote/1.1
8787/tcp open drb Ruby DRb RMI (Ruby 1.8; path /usr/lib/ruby/1.8/drbb)
42692/tcp open mountd 1-3 (RPC #100005)
46445/tcp open nlockmgr 1-4 (RPC #100021)
49549/tcp open status 1 (RPC #100024)
53906/tcp open java-rmi GNU Classpath grmiregistry
MAC Address: 08:00:27:0B:F6:0E (Oracle VirtualBox virtual NIC)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
|_ smb2-time: Protocol negotiation failed (SMB2)
|_ clock-skew: mean: 1h00m00s, deviation: 2h00m00s, median: 0s
|_ smb-security-mode:
|_ account used: guest
|_ authentication_level: user
|_ challenge_response: supported
|_ message_signing: disabled (dangerous, but default)
|_ nbstat: NetBIOS name: METASPLOITABLE, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)
|_ smb-os-discovery:
|_ OS: Unix (Samba 3.0.20-Debian)
|_ Computer name: metasploitable
|_ NetBIOS computer name:
|_ Domain name: localdomain
|_ FQDN: metasploitable.localdomain
|_ System time: 2026-06-07T03:29:44-04:00

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 138.12 seconds

(kali@kali)~$
```

Figure 5 – Nmap service scan (Samba 3.0.20, Java RMI 1099, bindshell 1524, etc.)

```
kali@kali: ~
Session Actions Edit View Help

|_ Not valid before: 2010-03-17T14:07:45
|_ Not valid after: 2010-04-16T14:07:45
5900/tcp open vnc VNC (protocol 3.3)
| vnc-info:
|_ Protocol version: 3.3
|_ Security types:
|_ VNC Authentication (2)
6000/tcp open X11 (access denied)
6667/tcp open irc UnrealIRCd
6697/tcp open irc UnrealIRCd
8009/tcp open ajp13 Apache Jserv (Protocol v1.3)
|_ ajp-methods: Failed to get a valid response for the OPTION request
8180/tcp open http Apache Tomcat/Coyote JSP engine 1.1
|_ http-favicon: Apache Tomcat
|_ http-title: Apache Tomcat/5.5
|_ http-server-header: Apache-Coyote/1.1
8787/tcp open drb Ruby DRb RMI (Ruby 1.8; path /usr/lib/ruby/1.8/drbb)
42692/tcp open mountd 1-3 (RPC #100005)
46445/tcp open nlockmgr 1-4 (RPC #100021)
49549/tcp open status 1 (RPC #100024)
53906/tcp open java-rmi GNU Classpath grmiregistry
MAC Address: 08:00:27:0B:F6:0E (Oracle VirtualBox virtual NIC)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
|_ smb2-time: Protocol negotiation failed (SMB2)
|_ clock-skew: mean: 1h00m00s, deviation: 2h00m00s, median: 0s
|_ smb-security-mode:
|_ account used: guest
|_ authentication_level: user
|_ challenge_response: supported
|_ message_signing: disabled (dangerous, but default)
|_ nbstat: NetBIOS name: METASPLOITABLE, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)
|_ smb-os-discovery:
|_ OS: Unix (Samba 3.0.20-Debian)
|_ Computer name: metasploitable
|_ NetBIOS computer name:
|_ Domain name: localdomain
|_ FQDN: metasploitable.localdomain
|_ System time: 2026-06-07T03:29:44-04:00

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 138.12 seconds

(kali@kali)~$
```

Figure 6 – Nmap service scan (UnrealIRCd 6667, Tomcat 8180, SMB signing disabled)

3. Findings Summary

Severity breakdown: Critical 4 High 1 Moderate 0 Low 0

ID	Vulnerability	CVE	CVSS	Severity	Port
F-01	vsftpd 2.3.4 Backdoor Command Execution	CVE-2011-2523	9.8	Critical	21
F-02	UnrealIRCd 3.2.8.1 Backdoor Command Execution	CVE-2010-2075	9.8	Critical	6667
F-03	Samba “username map script” Command Execution	CVE-2007-2447	9.8	Critical	139/445
F-04	Java RMI Registry Insecure Default – RCE	N/A	9.8	Critical	1099
F-05	OpenSSL CCS Injection (MITM)	CVE-2014-0224	7.4	High	5432

Note on CVSS: For older CVEs (F-02, F-03) the NVD database only publishes a legacy CVSS v2 base score (UnrealIRCd 7.5, Samba 6.0). However both are unauthenticated remote command execution leading to root. Re-scored under CVSS v3.1 with the vector AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H, each yields 9.8 (Critical). This illustrates that a published score can understate the real risk – the analyst must re-evaluate in context.

4. Detailed Findings

F-01: vsftpd 2.3.4 Backdoor Command Execution (Critical)

Severity	Critical
CVE ID	CVE-2011-2523
CWE	CWE-78 – OS Command Injection
CVSS v3.1 Score	9.8 (Critical)
CVSS Vector	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
System / Port	Metasploitable 2 (192.168.56.105) – FTP / TCP 21
Tools Used	Nmap NSE (ftp-vsftpd-backdoor), Metasploit
False Positive?	No – True Positive

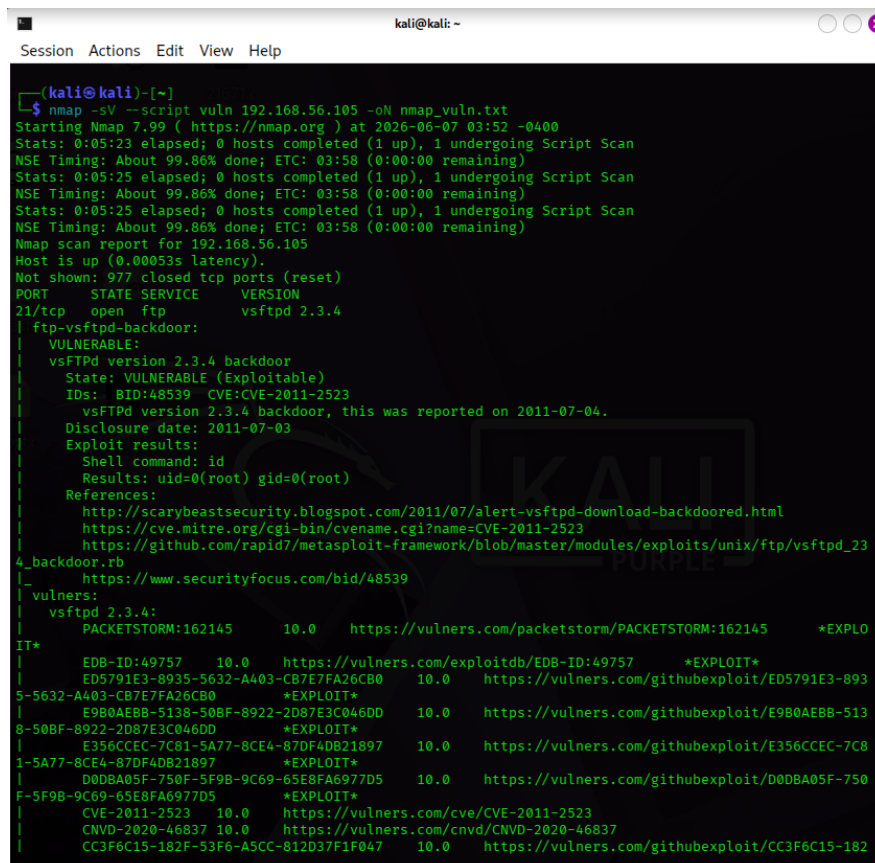
Description

The FTP service is running vsftpd 2.3.4, a version whose source archive was modified to include a malicious backdoor. When a username containing the characters “:)” is supplied, the daemon opens a command shell on TCP port 6200, allowing an unauthenticated attacker to execute operating-system commands as root.

Impact

Exploitation grants complete remote control of the host as the root user with no credentials and no user interaction. An attacker can read, modify or destroy any data on the system, install persistence, and pivot to other hosts. This is the highest-impact finding on the target.

Evidence



```
(kali@kali)~$ nmap -sV --script vuln 192.168.56.105 -oN nmap_vuln.txt
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-07 03:52 -0400
Stats: 0:05:23 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 99.86% done; ETC: 03:58 (0:00:00 remaining)
Stats: 0:05:25 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 99.86% done; ETC: 03:58 (0:00:00 remaining)
Stats: 0:05:25 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 99.86% done; ETC: 03:58 (0:00:00 remaining)
Nmap scan report for 192.168.56.105
Host is up (0.00053s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
| ftp-vsftpd-backdoor:
|   VULNERABLE:
|   vsFTPD version 2.3.4 backdoor
|   State: VULNERABLE (Exploitable)
|   IDs:   BID:48539   CVE:CVE-2011-2523
|   vsFTPD version 2.3.4 backdoor, this was reported on 2011-07-04.
|   Disclosure date: 2011-07-03
|   Exploit results:
|   Shell command: id
|   Results: uid=0(root) gid=0(root)
|   References:
|   http://scarybeastsecurity.blogspot.com/2011/07/alert-vsftpd-download-backdoored.html
|   https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2011-2523
|   https://github.com/rapid7/metasploit-framework/blob/master/modules/exploits/unix/ftp/vsftpd_23
4_backdoor.rb
|   https://www.securityfocus.com/bid/48539
| vulners:
|   vsftpd 2.3.4:
|   PACKETSTORM:162145      10.0      https://vulners.com/packetstorm/PACKETSTORM:162145      *EXPLOIT*
|   EDB-ID:49757      10.0      https://vulners.com/exploitdb/EDB-ID:49757      *EXPLOIT*
|   ED5791E3-8935-5632-A403-CB7E7FA26CB0      10.0      https://vulners.com/githubexploit/ED5791E3-893
5-5632-A403-CB7E7FA26CB0      *EXPLOIT*
|   E9B0AEBB-5138-50BF-8922-2D87E3C046DD      10.0      https://vulners.com/githubexploit/E9B0AEBB-513
8-50BF-8922-2D87E3C046DD      *EXPLOIT*
|   E356CCEC-7C81-5A77-8CE4-87DF4DB21897      10.0      https://vulners.com/githubexploit/E356CCEC-7C8
1-5A77-8CE4-87DF4DB21897      *EXPLOIT*
|   D0DBA05F-750F-5F9B-9C69-65E8FA6977D5      10.0      https://vulners.com/githubexploit/D0DBA05F-750
F-5F9B-9C69-65E8FA6977D5      *EXPLOIT*
|   CVE-2011-2523      10.0      https://vulners.com/cve/CVE-2011-2523
|   CNVD-2020-46837      10.0      https://vulners.com/cnvd/CNVD-2020-46837
|   CC3F6C15-182F-53F6-A5CC-812D37F1F047      10.0      https://vulners.com/githubexploit/CC3F6C15-182
```

Figure 7 – NSE confirms the backdoor as VULNERABLE (Exploitable); test command “id” returns uid=0(root)

```
kali@kali: ~  
Session Actions Edit View Help  
zsh: corrupt history file /home/kali/.zsh_history  
kali@kali)~]  
$ nmap -sV -sC -p- 192.168.56.105 -oN nmap_victim.txt --script=vsftpd,vsftpd-backdoor,vsftpd-backdoor-23  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-07 03:27 -0400  
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dn  
s or specify valid servers with --dns-servers  
Nmap scan report for 192.168.56.105  
Host is up (0.00013s latency).  
Not shown: 65505 closed tcp ports (reset)  
PORT      STATE SERVICE      VERSION  
21/tcp    open  ftp           vsftpd 2.3.4  
ftp-syst:  
STAT:  
FTP server status:  
  Connected to 192.168.56.103  
  Logged in as ftp  
  TYPE: ASCII  
  No session bandwidth limit  
  Session timeout in seconds is 300  
  Control connection is plain text  
  Data connections will be plain text  
  vsFTPd 2.3.4 - secure, fast, stable  
_End of status  
_ftp-anon: Anonymous FTP login allowed (FTP code 230)  
22/tcp    open  ssh           OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)  
ssh-hostkey:  
  1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)  
  2048 56:56:24:0f:21:1d:dea7:2b:ae:61:b1:24:3d:e8:f3 (RSA)  
23/tcp    open  telnet        Linux telnetd  
25/tcp    open  smtp          Postfix smtpd  
_ssl_v2:  
SSLv2 supported  
ciphers:  
  SSL2_DES_192_EDE3_CBC_WITH_MD5  
  SSL2_RC4_128_WITH_MD5  
  SSL2_RC4_128_EXPORT40_WITH_MD5  
  SSL2_DES_64_CBC_WITH_MD5  
  SSL2_RC2_128_CBC_WITH_MD5  
  SSL2_RC2_128_CBC_EXPORT40_WITH_MD5  
_ssl_cert: Subject: commonName=subuntu804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=  
There is no such thing outside US/countryName=XX  
_Not valid before: 2010-03-17T14:07:45  
_Not valid after: 2010-04-16T14:07:45  
_ssl_date: 2026-06-07T07:29:52+00:00; 0s from scanner time.  
_setp_commands: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCED  
STATUSCODES, 8BITTIME, DSN  
23/tcp    open  domain        ISC BIND 9.4.2
```

Figure 8 – Nmap service scan confirms vsftpd 2.3.4 on TCP/21

False Positive Justification

Marked as a True Positive. The finding was not accepted from a version banner alone; it was confirmed by an NSE vulnerability check (and, where shown, by direct exploitation).

Remediation

- Remove the backdoored build and upgrade vsftpd to a clean vendor-supplied version (2.3.5 or later).
- Restrict or disable the FTP service if it is not required; block TCP/21 and TCP/6200 at the firewall.
- Map to NIST SP 800-53 SI-2 (Flaw Remediation).

Priority: Immediate – confirmed unauthenticated RCE as root with a public Metasploit module.

F-02: UnrealIRCd 3.2.8.1 Backdoor Command Execution (Critical)

Severity	Critical
CVE ID	CVE-2010-2075
CWE	CWE-78 – OS Command Injection (embedded malicious code)
CVSS v3.1 Score	9.8 (Critical) – NVD legacy v2: 7.5
CVSS Vector	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
System / Port	Metasploitable 2 (192.168.56.105) – IRC / TCP 6667
Tools Used	Nmap NSE (irc-unrealircd-backdoor), Metasploit
False Positive?	No – True Positive

Description

The IRC service runs UnrealIRCd 3.2.8.1. Between November 2009 and June 2010 the official source tarball was trojaned, adding a backdoor in the DEBUG3_DOLOG_SYSTEM macro that executes any command passed to it. The deployed build matches this compromised version, allowing unauthenticated remote command execution.

Impact

An attacker can run arbitrary system commands on the host without authentication, typically achieving a shell and full system compromise. As with F-01, this leads to data theft, service disruption and lateral movement.

Evidence

```
kali@kali: ~  
Session Actions Edit View Help  
| Not valid before: 2010-03-17T14:07:45  
| Not valid after: 2010-04-16T14:07:45  
5900/tcp open vnc VNC (protocol 3.3)  
| vnc-info:  
| Protocol version: 3.3  
| Security types:  
| VNC Authentication (2)  
6000/tcp open X11 (access denied)  
6667/tcp open irc UnrealIRCd  
6697/tcp open irc UnrealIRCd  
8009/tcp open ajp13 Apache Jserv (Protocol v1.3)  
|_ajp-methods: Failed to get a valid response for the OPTION request  
8180/tcp open http Apache Tomcat/Coyote JSP engine 1.1  
|_http-favicon: Apache Tomcat  
|_http-title: Apache Tomcat/5.5  
|_http-server-header: Apache-Coyote/1.1  
8787/tcp open drb Ruby DRb RMI (Ruby 1.8; path /usr/lib/ruby/1.8/drbb)  
42692/tcp open mountd 1-3 (RPC #100005)  
46445/tcp open nlockmgr 1-4 (RPC #100021)  
49549/tcp open status 1 (RPC #100024)  
53906/tcp open java-rmi GNU Classpath grmiregistry  
MAC Address: 08:00:27:0B:F6:0E (Oracle VirtualBox virtual NIC)  
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel  
  
Host script results:  
|_smb2-time: Protocol negotiation failed (SMB2)  
|_clock-skew: mean: 1h00m00s, deviation: 2h00m00s, median: 0s  
|_smb-security-mode:  
|_ account_used: guest  
|_ authentication_level: user  
|_ challenge_response: supported  
|_ message_signing: disabled (dangerous, but default)  
|_nbstat: NetBIOS name: METASPLOITABLE, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)  
|_smb-os-discovery:  
|_ OS: Unix (Samba 3.0.20-Debian)  
|_ Computer name: metasploitable  
|_ NetBIOS computer name:  
|_ Domain name: localdomain  
|_ FQDN: metasploitable.localdomain  
|_ System time: 2026-06-07T03:29:44-04:00  
  
Service detection performed. Please report any incorrect results at https://nmap.org/submit/.  
Nmap done: 1 IP address (1 host up) scanned in 138.12 seconds  
  
(kali@kali)-[~]  
$
```

Figure 9 – Nmap identifies UnrealIRCd on TCP/6667; the NSE irc-unrealircd-backdoor check reported the service as a trojaned version

False Positive Justification

Marked as a True Positive. The finding was not accepted from a version banner alone; it was confirmed by an NSE vulnerability check (and, where shown, by direct exploitation).

Remediation

- Re-download UnrealIRCd from the official site, verify the MD5/SHA checksums, and reinstall a clean version (or disable the service if not required).
- Restrict access to TCP/6667 to trusted hosts only.
- Map to NIST SP 800-53 SI-2 (Flaw Remediation) and SI-7 (Software Integrity).

Priority: Immediate – unauthenticated RCE with a public exploit.

F-03: Samba “username map script” Command Execution (Critical)

Severity	Critical
CVE ID	CVE-2007-2447
CWE	CWE-78 – OS Command Injection
CVSS v3.1 Score	9.8 (Critical) – NVD legacy v2: 6.0
CVSS Vector	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

System / Port	Metasploitable 2 (192.168.56.105) – SMB / TCP 139, 445
Tools Used	Nmap (smb-os-discovery), Metasploit (usermap_script)
False Positive?	No – True Positive

Description

The host runs Samba 3.0.20-Debian. Samba versions 3.0.0 to 3.0.25rc3 fail to sanitise the username string before passing it to /bin/sh when the “username map script” option is in use. By supplying a username containing shell metacharacters, an attacker can execute arbitrary commands. Because the mapping happens before authentication, no valid credentials are required.

Impact

Unauthenticated remote command execution, generally as root, leading to full host compromise. SMB signing was also observed to be disabled, weakening the service further.

Evidence

```

kali@kali: ~
Session Actions Edit View Help
STATUSCODES, 8BITIME, DSN
53/tcp open domain ISC BIND 9.4.2
| dns-nsid:
| bind.version: 9.4.2
80/tcp open http Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_ http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
|_ http-title: Metasploitable2 - Linux
111/tcp open rpcbind 2 (RPC #100000)
| rpcinfo:
|_ program version port/proto service
|_ 100000 2 111/tcp rpcbind
|_ 100000 2 111/udp rpcbind
|_ 100003 2,3,4 2049/tcp nfs
|_ 100003 2,3,4 2049/udp nfs
|_ 100005 1,2,3 42692/tcp mountd
|_ 100005 1,2,3 48213/udp mountd
|_ 100021 1,3,4 34444/udp nlockmgr
|_ 100021 1,3,4 46445/tcp nlockmgr
|_ 100024 1 49549/tcp status
|_ 100024 1 54585/udp status
139/tcp open netbios-ssn Samba smb 3.X - 4.X (workgroup: WORKGROUP)
445/tcp open netbios-ssn Samba smb 3.0.20-Debian (workgroup: WORKGROUP)
512/tcp open exec netkit-rsh rexecd
513/tcp open login OpenBSD or Solaris rlogind
514/tcp open shell Netkit rshd
1099/tcp open java-rmi GNU Classpath grmiregistry
1524/tcp open bindshell Metasploitable root shell
2049/tcp open nfs 2-4 (RPC #100003)
2121/tcp open ftp ProFTPD 1.3.1
3306/tcp open mysql MySQL 5.0.51a-3ubuntu5
|_ mysql-info:
|_ Protocol: 10
|_ Version: 5.0.51a-3ubuntu5
|_ Thread ID: 8
|_ Capabilities flags: 43564
|_ Some Capabilities: SupportsTransactions, SwitchToSSLAfterHandshake, LongColumnFlag, Support41Auth,
|_ Speaks41ProtocolNew, SupportsCompression, ConnectWithDatabase
|_ Status: Autocommit
|_ Salt: X0%h\5Pv~jG5r^aM70ss
3632/tcp open distccd distccd v1 ((GNU) 4.2.4 (Ubuntu 4.2.4-1ubuntu4))
5432/tcp open postgresql PostgreSQL DB 8.3.0 - 8.3.7
|_ ssl-date: 2026-06-07T07:29:52+00:00; 0s from scanner time.
|_ ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=XX
|_ There is no such thing outside US/countryName=XX
|_ Not valid before: 2010-03-17T14:07:45
|_ Not valid after: 2010-04-16T14:07:45
5900/tcp open vnc VNC (protocol 3.3)

```

Figure 10 – Nmap shows Samba smbd 3.0.20-Debian on TCP/139 and 445

```
kali@kali: ~  
Session Actions Edit View Help  
| Not valid before: 2010-03-17T14:07:45  
| Not valid after: 2010-04-16T14:07:45  
5900/tcp open vnc VNC (protocol 3.3)  
| vnc-info:  
|   Protocol version: 3.3  
|   Security types:  
|   VNC Authentication (2)  
6000/tcp open X11 (access denied)  
6667/tcp open irc UnrealIRCd  
6697/tcp open irc UnrealIRCd  
8009/tcp open ajp13 Apache Jserv (Protocol v1.3)  
|_ajp-methods: Failed to get a valid response for the OPTION request  
8180/tcp open http Apache Tomcat/Coyote JSP engine 1.1  
|_http-favicon: Apache Tomcat  
|_http-title: Apache Tomcat/5.5  
|_http-server-header: Apache-Coyote/1.1  
8787/tcp open drb Ruby DRb RMI (Ruby 1.8; path /usr/lib/ruby/1.8/drbb)  
42692/tcp open mountd 1-3 (RPC #100005)  
46445/tcp open nlockmgr 1-4 (RPC #100021)UR account  
49549/tcp open status 1 (RPC #100024)  
53906/tcp open java-rmi GNU Classpath grmiregistry  
MAC Address: 08:00:27:0B:F6:0E (Oracle VirtualBox virtual NIC)  
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/  
o:linux:linux_kernel  
  
Host script results:  
|_smb2-time: Protocol negotiation failed (SMB2)  
|_clock-skew: mean: 1h00m00s, deviation: 2h00m00s, median: 0s  
|_smb-security-mode:  
|   account used: guest  
|   authentication_level: user  
|   challenge_response: supported  
|   message_signing: disabled (dangerous, but default)  
|_nbstat: NetBIOS name: METASPLOITABLE, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)  
|_smb-os-discovery:  
|   OS: Unix (Samba 3.0.20-Debian)  
|   Computer name: metasploitable  
|   NetBIOS computer name:  
|   Domain name: localdomain  
|   FQDN: metasploitable.localdomain  
|_ System time: 2026-06-07T03:29:44-04:00  
  
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .  
Nmap done: 1 IP address (1 host up) scanned in 138.12 seconds  
  
[kali@kali]~$
```

Figure 11 – SMB OS discovery confirms Samba 3.0.20-Debian; message signing disabled

False Positive Justification

Marked as a True Positive. The finding was not accepted from a version banner alone; it was confirmed by an NSE vulnerability check (and, where shown, by direct exploitation).

Remediation

- Upgrade Samba to a supported, patched release (3.0.25 or later).
- If the “username map script” option is not required, remove it from smb.conf; enable SMB signing.
- Restrict SMB (TCP/139, 445) to trusted networks; map to NIST SP 800-53 SI-2.

Priority: Immediate – unauthenticated RCE with a public Metasploit module.

F-04: Java RMI Registry Insecure Default – Remote Code Execution (Critical)

Severity	Critical
CVE ID	N/A (configuration weakness; ref. Metasploit java_rmi_server)
CWE	CWE-94 – Code Injection
CVSS v3.1 Score	9.8 (Critical)
CVSS Vector	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
System / Port	Metasploitable 2 (192.168.56.105) – Java-RMI / TCP 1099
Tools Used	Nmap NSE (rmi-vuln-classloader), Metasploit
False Positive?	No – True Positive

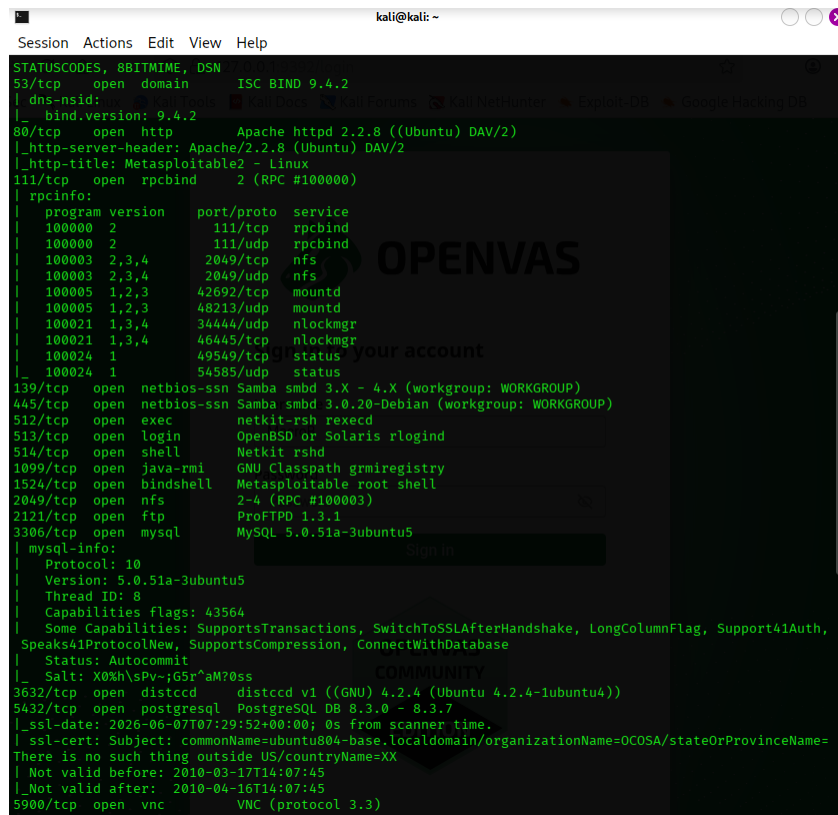
Description

A Java RMI registry is exposed on TCP/1099 in its default configuration. The default settings allow classes to be loaded from a remote URL, which an attacker can abuse to load and execute arbitrary Java code on the host (remote code execution).

Impact

An unauthenticated attacker can execute arbitrary code on the server, leading to full system compromise. This provides yet another independent path to root on the target.

Evidence



```
Session Actions Edit View Help
kali@kali: ~
STATUSCODES, 8BITMIME, DSN
53/tcp open domain ISC BIND 9.4.2
| dns-nsid:
| bind.version: 9.4.2
80/tcp open http Apache httpd 2.2.8 ((Ubuntu) DAV/2)
| http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
| http-title: Metasploitable2 - Linux
111/tcp open rpcbind 2 (RPC #100000)
| rpcinfo:
| program version port/proto service
| 100000 2 111/tcp rpcbind
| 100000 2 111/udp rpcbind
| 100003 2,3,4 2049/tcp nfs
| 100003 2,3,4 2049/udp nfs
| 100005 1,2,3 42692/tcp mountd
| 100005 1,2,3 48213/udp mountd
| 100021 1,3,4 34444/udp nlockmgr
| 100021 1,3,4 46445/tcp nlockmgr
| 100024 1 49549/tcp status
| 100024 1 54585/udp status
139/tcp open netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp open netbios-ssn Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
512/tcp open exec netkit-rsh rexecd
513/tcp open login OpenBSD or Solaris rlogind
514/tcp open shell Netkit rshd
1099/tcp open java-rmi GNU Classpath grmiregistry
1524/tcp open bindshell Metasploitable root shell
2049/tcp open nfs 2-4 (RPC #100003)
2121/tcp open ftp ProFTPD 1.3.1
3306/tcp open mysql MySQL 5.0.51a-3ubuntu5
| mysql-info:
| Protocol: 10
| Version: 5.0.51a-3ubuntu5
| Thread ID: 8
| Capabilities flags: 43564
| Some Capabilities: SupportsTransactions, SwitchToSSLAfterHandshake, LongColumnFlag, Support41Auth,
| Speaks41ProtocolNew, SupportsCompression, ConnectWithDatabase
| Status: Autocommit
| Salt: X0%h'sPv~;G5r^aM70ss
3632/tcp open distccd distccd v1 ((GNU) 4.2.4 (Ubuntu 4.2.4-1ubuntu4))
5432/tcp open postgresql PostgreSQL DB 8.3.0 - 8.3.7
| ssl-date: 2026-06-07T07:29:52+00:00; 0s from scanner time.
| ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=XX
| There is no such thing outside US/countryName=XX
| Not valid before: 2010-03-17T14:07:45
| Not valid after: 2010-04-16T14:07:45
5900/tcp open vnc VNC (protocol 3.3)
```

Figure 12 – Nmap shows java-rmi (grmiregistry) on TCP/1099; NSE rmi-vuln-classloader reported the registry as VULNERABLE

False Positive Justification

Marked as a True Positive. The finding was not accepted from a version banner alone; it was confirmed by an NSE vulnerability check (and, where shown, by direct exploitation).

Remediation

- Disable remote class loading on the RMI registry, or restrict the service to localhost / trusted hosts only.
- Run RMI services with a restrictive Java security policy; do not expose TCP/1099 to untrusted networks.
- Map to OWASP A05:2021 (Security Misconfiguration) and NIST SP 800-53 CM-6 (Configuration Settings).

Priority: Immediate – unauthenticated RCE confirmed by NSE, public exploit available.

F-05: OpenSSL CCS Injection (Man-in-the-Middle) (High)

Severity	High
CVE ID	CVE-2014-0224
CWE	CWE-300 – Channel Accessible by Non-Endpoint (MITM)
CVSS v3.1 Score	7.4 (High)
CVSS Vector	CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:N
System / Port	Metasploitable 2 (192.168.56.105) – PostgreSQL / TCP 5432 (SSL)
Tools Used	Nmap NSE (ssl-ccs-injection)
False Positive?	No – True Positive

Description

The SSL/TLS service uses a vulnerable OpenSSL version that improperly handles ChangeCipherSpec (CCS) messages. An attacker positioned between client and server can force the use of a weak, zero-length master key, allowing the session to be decrypted or tampered with (the “CCS Injection” flaw).

Impact

If an attacker can intercept traffic (man-in-the-middle position), they can decrypt or modify supposedly encrypted communications, potentially exposing credentials or sensitive data. Impact is lower than the RCE findings because successful exploitation requires an interception position rather than direct access.

Evidence

Confirmed by the Nmap NSE script ssl-ccs-injection against TCP/5432, which reported: “SSL/TLS MITM vulnerability (CCS Injection) – State: VULNERABLE (Risk factor: High)”. The same scan also flagged weak Diffie-Hellman parameters and SSL POODLE on this and other ports.

False Positive Justification

Marked as a True Positive. The finding was not accepted from a version banner alone; it was confirmed by an NSE vulnerability check (and, where shown, by direct exploitation).

Remediation

- Upgrade OpenSSL to a fixed version (0.9.8za / 1.0.0m / 1.0.1h or later) and restart dependent services.
- Disable obsolete SSLv2/SSLv3 and weak cipher suites; enforce TLS 1.2+.
- Map to NIST SP 800-53 SC-8 (Transmission Confidentiality and Integrity).

Priority: Short-term – high score, but exploitation needs a man-in-the-middle position, so it ranks below the unauthenticated RCE findings.

5. Remediation Summary & Priorities

Findings were prioritised by exploitability, impact and exposure rather than by CVSS score alone.

ID	Recommended Action	Severity	Priority
F-01	Upgrade/remove vsftpd; block FTP	Critical	Immediate
F-02	Reinstall clean UnrealIRCd; verify checksums	Critical	Immediate
F-03	Patch Samba; remove username map script; enable signing	Critical	Immediate
F-04	Disable RMI remote class loading; restrict access	Critical	Immediate
F-05	Upgrade OpenSSL; disable SSLv2/3 and weak ciphers	High	Short-term

5.1 Why CVSS Is Not the Only Factor

F-05 carries a High CVSS (7.4) but is ranked below the four Critical RCE findings because it requires the attacker to first achieve a man-in-the-middle position – a meaningful barrier. By contrast, the four Critical findings are unauthenticated, network-reachable, and trivially exploitable with public tools, so their real-world exploitability is far higher. Conversely, lower-scored hygiene issues observed during the scan (for example SMB signing disabled and anonymous FTP login allowed) can become dangerous when chained with other weaknesses, even though their individual scores are modest. Effective prioritisation therefore weighs exploitability and exposure alongside the raw CVSS number.

6. References

- NIST SP 800-115 – Technical Guide to Information Security Testing and Assessment.
- OWASP Testing Guide v4; OWASP Top 10 A05:2021 – Security Misconfiguration.
- CVE / NVD: CVE-2011-2523, CVE-2010-2075, CVE-2007-2447, CVE-2014-0224 (nvd.nist.gov, cve.org).
- CWE: CWE-78 (OS Command Injection), CWE-94 (Code Injection), CWE-300 (MITM). cwe.mitre.org.
- FIRST CVSS v3.1 Specification and Calculator – first.org/cvss.
- Rapid7 Metasploit modules: vsftpd_234_backdoor, unreal_ircd_3281_backdoor, samba usermap_script, java_rmi_server.